AI GOVERNANCE

PRACTITIONER TOOLKIT + CONTENT ENGINE

Prompt B of II: From Foundation to Market

Catalyst Works Consulting
Boubacar Barry, Founder

April 16, 2026 | Confidential | Builds on Foundation Research (Prompt A)

PART 1: THE DISCOVERY SESSION FRAMEWORK

1.1 Session Architecture

This is a 60-minute structured working session, not a sales call. The frame matters: you are conducting a diagnostic, not pitching a service. That distinction changes how clients engage with it. Call it what it is: an AI Governance Diagnostic Session.

Phase	Time	What Happens
Open	0-5 min	Frame the session. Set the agenda. Establish that you are here to understand their situation, not to sell them anything today. One sentence on what you do, then stop talking about yourself.
Current State	5-20 min	Diagnostic questions: AI usage inventory, risk exposure, existing policies. Listen more than you speak. Take visible notes. Surface the gap between what they think they have and what they actually have.
Accountability Map	20-30 min	Identify who owns what. Who is responsible for AI decisions today? Who would be called if something went wrong? What happens when an employee uses an unapproved tool? This is where most SMBs discover they have no answers.
Vendor Exposure	30-40 min	Walk through their AI vendor stack. For each tool: what data flows into it? What does the vendor's contract actually say about data retention and model training? Most clients have not read these clauses.
Maturity Score	40-50 min	Score them on the maturity model (Section 1.3). Do this visibly, in the session. A live scoring creates a shared reference point and signals that you are measuring something real, not improvising.
Closing Move	50-60 min	Reflect back what you heard. Name the top two or three gaps. Present the output template (Section 1.4) and explain it will arrive within 48 hours. Close with one specific question: 'Is fixing this in your top five priorities right now?'

Opening Framing Script

OPEN

Today I want to understand how your organization is actually using AI, who is accountable for those decisions, and where your exposure is. I am going to ask specific questions and take notes. At the end, I will give you a score on a governance maturity scale and tell you the two or three things that need attention most urgently. You will have a written summary within 48 hours. Sound useful?

Closing Move (The One Question)

CLOSE

Based on what we just found, [Name the top gap specifically — e.g., 'you have no approved vendor list and three tools with client data in them'] — is closing that kind of exposure in your top priorities right now? Because if it is, I have a specific engagement that addresses exactly this.

1.2 Diagnostic Questions by Category

These are the exact questions to ask, in order. Do not ask all of them. Use the first one in each category to gauge depth, then follow the thread. Your job is to surface the gap, not to exhaust the topic.

CATEGORY A: Current AI Usage	
Q1	Walk me through every AI tool your team uses on a regular basis — including tools built into software you already use, like AI features in your CRM, your email, or your accounting software.
Q2	Are there tools your employees are using informally, outside of anything you have officially approved?
Q3	Which of these tools touches client data, employee data, or proprietary business information?
Q4	Who made the decision to adopt each of these tools, and what was the approval process?
Q5	Is there an AI system that is making or significantly influencing decisions that used to be made by a human?

CATEGORY B: Risk Exposure	
Q1	If one of your AI tools gave a client wrong information or made a discriminatory decision, what would happen? Who would handle it, and what is your liability exposure?
Q2	Have you had any situation where an AI tool produced an output that surprised you, embarrassed you, or caused a problem?
Q3	If a client asked you today how you use AI and what data protections you have in place, what would you say?
Q4	Are any of your clients in regulated industries — healthcare, financial services, legal, HR? Do you know if your AI use creates compliance obligations for them?
Q5	What would a data breach involving an AI vendor cost you — financially, reputationally, in terms of client relationships?

CATEGORY C: Existing Policies	
Q1	Do you have a written policy that governs how your team uses AI? If yes, where does it live and when was it last updated?
Q2	Does your employee handbook say anything about AI use?
Q3	What data are employees explicitly prohibited from inputting into AI tools? Is this written anywhere or understood informally?
Q4	If I asked one of your employees tomorrow what they are and are not allowed to do with AI, what would they say?
Q5	Have you reviewed your client contracts recently to check whether your AI use is consistent with your data handling obligations?

CATEGORY D: Stakeholder Accountability	
Q1	If something goes wrong with an AI system tomorrow, who is the first call? Who owns the response?
Q2	Who in your organization has authority to approve or reject the adoption of a new AI tool?
Q3	Does your leadership team have a shared understanding of what your AI risk exposure is?
Q4	Has AI governance ever come up in a board meeting, an investor conversation, or a client due diligence process?

Q5	If a regulator or auditor asked you to demonstrate responsible AI use, could you produce evidence of that within 48 hours?

CATEGORY E: Vendor Relationships	
Q1	Have you read the AI-specific data provisions in your vendor contracts? Specifically: does your vendor use your data to train their models?
Q2	Do you have a list of AI vendors your team is approved to use? Who maintains it?
Q3	When you evaluate a new AI software vendor, what specifically do you ask about their AI practices?
Q4	If a vendor's AI system failed or was compromised, what notification would you receive and how quickly?
Q5	Do you have any contractual protections — indemnification, limitation of liability — covering AI-related vendor failures?

1.3 Governance Maturity Model

Score the client during the session. Each level has a name, a description of what it looks like in practice, the immediate risk it represents, and the specific next step to recommend.

Level	Name	What It Looks Like	Immediate Risk	Next Step
LEVEL 0	**Ungoverned**	No AI inventory. No written policies. Employees using AI tools at discretion. Leadership has no visibility.	Maximum. Client data in unapproved tools. No incident response capability. Regulatory exposure if any state AI law applies.	Complete AI inventory first. Then acceptable use policy within 30 days.
LEVEL 1	**Aware but Informal**	Leadership knows AI is being used. Some informal norms exist. No written policy. No AI inventory. Vendor contracts unreviewed.	High. Informal norms are unenforceable and unevenly applied. No documentation means no defense if challenged.	Document the norms. Build an AI inventory. Formalize an acceptable use policy. Assign accountability.
LEVEL 2	**Policy Exists**	A written AI policy exists. AI inventory is partially complete. Accountability is named for some systems. Basic vendor review process in place.	Moderate. Policy may not cover all use cases. Training may be absent. Incident response plan likely missing.	Complete inventory. Add incident response and human oversight protocols. Train staff. Establish review cadence.
LEVEL 3	**Production-Ready**	Complete AI inventory. Full policy with all 14 sections. Named accountable owners. Incident response tested. Staff trained. Quarterly review cadence.	Low. Governance is functional and defensible. Remaining risk is drift: policy aging faster than AI adoption.	Monitor and maintain. Consider ISO 42001 alignment as a trust signal. Use governance as a competitive differentiator.

1.4 Session Output Template

This document goes to the client within 48 hours. It is designed to be forwarded internally, which is how it generates pull for follow-on work. Keep it to two pages maximum. The goal is to be the most useful two pages they receive all month.

FORMAT NOTE	*Deliver this as a clean PDF with your branding. Title it: '[Client Name] AI Governance Diagnostic — Catalyst Works Consulting — [Date]'. It should look like a deliverable worth sharing, not like meeting notes.*

SESSION OUTPUT TEMPLATE — SECTION BY SECTION

1. WHAT WE COVERED

One paragraph, 3-4 sentences. Summarize the session scope without editorializing. This establishes shared context for anyone who was not in the room.

2. YOUR GOVERNANCE MATURITY SCORE

State the score: Level 0 / 1 / 2 / 3. One sentence on what that level means for this specific organization. Do not soften it, but do not be dramatic. A score is a measurement, not a judgment.

3. TOP THREE GAPS IDENTIFIED

Specific, not generic. 'No written acceptable use policy' is acceptable. 'Governance documentation needs attention' is not. Each gap gets one sentence on why it matters and one sentence on what unaddressed risk it creates.

4. AI TOOL INVENTORY (AS DOCUMENTED)

List every AI tool identified during the session. Tool name | Primary use | Data types input | Risk tier (L/M/H). Even an incomplete inventory is valuable because it makes visible what was invisible.

5. ACCOUNTABILITY MAP (AS IDENTIFIED)

Who was named as accountable for what. Gaps in accountability are noted explicitly: 'No accountable owner was identified for [tool].'

6. RECOMMENDED NEXT STEP

One specific recommendation. Tied to the maturity level. States what the outcome of that step looks like and roughly how long it should take. This is where the follow-on engagement is implicitly introduced — not pitched.

7-DAY ACTION	**Book one real diagnostic session this week. Not a practice run — a real potential client. The session is the product. Run it, produce the output template, and send it within 48 hours. That is the proof of concept.**

PART 2: OBJECTION HANDLING AND THE BUSINESS CASE

2.1 Common Objections and Direct Responses

Do not rehearse these as scripts. Internalize the logic. The goal is to be genuinely persuasive, not to have a clever comeback. Each response reframes the objection without dismissing it.

"We're too small to need this."

The NYC MyCity chatbot that told business owners they could steal tips and ignore harassment complaints was not a large organization problem. Size determines complexity of governance, not whether you need it. A three-person firm with one AI tool touching client data is exposed. The scale of the governance needs to match the scale of the operation — which is exactly what I help design.

"We don't really use AI that much."

Let me ask you something: does your CRM have AI features? Does your email platform? Your accounting software? AI is embedded in most business software now and you may be using it without knowing it. The question is not whether you use AI — it is whether you know how it is using your data.

"We already have a privacy policy."

A privacy policy covers how you handle data you collect. It does not cover how your employees use AI tools, what data they put into those tools, how your vendors use that data, or who is accountable when an AI system makes a wrong call. Those are four separate governance gaps that a privacy policy does not touch.

"This feels like compliance overhead."

I understand that reaction. Here is the alternative: one of your employees puts a client contract into an AI tool whose vendor uses it to train their model. Your client finds out. You have no policy, no documentation, no accountability structure. The conversation you have then costs more — in legal exposure, lost client trust, and management time — than governance would have. This is not overhead. It is insurance that you pay once and use forever.

"We'll deal with this when regulations require it."

Colorado's law takes effect June 2026. Texas and Illinois went live January 2026. California added laws in 2025. If you have employees or clients in those states, it is already required. And the organizations that wait for a regulatory trigger always pay more to remediate than they would have spent to build it right the first time. The cost of reactive governance is always higher than proactive governance.

"We don't have budget for this right now."

What is your legal bill if one of your vendors has an AI data incident and you are named in the client complaint? What does it cost you if a prospective client asks about your AI practices in a due diligence call and you have no answer? Governance is not a discretionary expense. It is a hedge against a specific class of operational and legal risk. What I do is find the minimum viable version that gives you that protection at a price that makes sense for your operation.

"Can't I just use a template I find online?"

You can. The same way you can use a contract template you find online. The risk is that a generic template does not reflect your specific AI tool stack, your actual data practices, your real vendor relationships, or the laws that apply to your specific jurisdiction and industry. And a governance policy that does not reflect your actual operations is not just useless — it is actively misleading if it ever gets scrutinized.

2.2 The Business Case for Skeptical Owner-Operators

Anchor every conversation to outcomes the client already cares about. Do not lead with compliance. Lead with the thing that wakes them up at 3am.

Liability

If an AI tool you use makes a wrong decision — misclassifies a client, gives bad advice, discriminates in hiring — and there is no governance documentation, you cannot demonstrate that you acted reasonably. Governance is what creates a paper trail of responsible practice. Without it, you are exposed. With it, you have a defense.

Operational Continuity

What happens when the AI tool your team depends on changes its pricing, gets acquired, or changes its data practices? A governance program includes vendor risk management that tells you what tools you are dependent on, what your exit strategy is, and what the data implications of a vendor change are. Organizations without this find out the hard way.

Vendor Risk

Most SMBs have signed AI vendor contracts without reading the AI-specific clauses. Some vendors explicitly reserve the right to use your data to train their models. Some do not notify you of incidents unless required by law — which varies by jurisdiction. A governance program includes a vendor assessment process that asks the right questions before you are locked in.

Employee Behavior

Your employees are making decisions today about what data they put into AI tools. Without a written policy, those decisions are ungoverned. An employee sending client financials to an AI tool to generate a report is not malicious — they are solving a problem with the tools available to them. Governance gives them a framework so they solve problems in ways that do not create new ones.

Competitive Positioning

Your enterprise clients and prospects are starting to ask about AI governance in due diligence processes. If you cannot answer that question — 'What is your AI governance policy?' — you are at a disadvantage against competitors who can. Governance is increasingly a procurement requirement, not just an ethical nice-to-have.

2.3 Trigger Events: When the Conversation Becomes Easy

These are the moments when a prospect who was cold becomes warm. Watch for them in news, in client conversations, and on social media.

- A competitor, industry peer, or well-known company in their sector has an AI-related incident (data breach, discriminatory output, chatbot failure). The incident does not need to be in their exact industry — adjacency is enough.
- A new state AI law takes effect in their operating jurisdiction (Colorado June 2026, for example). Regulatory deadlines create urgency that no amount of positioning can manufacture.
- A client sends a vendor questionnaire with AI governance questions in it. This is the fastest-growing trigger. Enterprise procurement teams are adding AI governance to due diligence checklists.
- They are applying for a contract or grant that requires a compliance statement or evidence of responsible AI practices.
- A new employee, board member, or investor asks 'what is your AI policy?' and they do not have an answer.
- They are onboarding a new AI tool and someone internally raises concerns about data security or liability.
- They experience an internal AI failure — an AI tool produces incorrect output that affects a client or a business decision. This is the event that converts skeptics into buyers.

SIGNAL MONITORING TIP	*Set Google Alerts for: 'AI governance lawsuit', 'AI bias lawsuit', 'AI data breach SMB', 'AI vendor contract data'. When these surface, that is your content hook and your prospecting context.*

7-DAY ACTION	**Write out your personal answer to 'We're too small to need this' and 'We'll deal with it when regulations require it.' Say them out loud until the response is natural, not recited. Then use them in your next three prospecting conversations.**

PART 3: IMPLEMENTATION ROADMAP FOR CLIENTS

3.1 Three-Tier Implementation Roadmap

Present this roadmap to clients at the end of the diagnostic session or in the output template. It gives them a destination and contextualizes the immediate next step within a larger journey.

TIER 1: MINIMUM VIABLE GOVERNANCE — "Not Exposed"	
Target Organization	1-50 employees. AI adoption is opportunistic. No dedicated IT or compliance function. Primary concern: not being caught flat-footed.
Key Deliverables	Complete AI inventory (every tool, every use, every data type). Acceptable use policy (what is permitted, what is prohibited, who approves new tools). Named accountable owner for each tool. Basic vendor data assessment for highest-risk tools. Employee communication (one-page summary of the policy).
Time to Implement	30-60 days with active client participation. Practitioner-led sessions: 2-3 working sessions plus async review.
Common Blockers	Client cannot find time to complete the AI inventory. Leadership has not agreed on what 'prohibited use' means. Vendor contracts are not accessible or are unsigned PDFs in someone's inbox.
Signs Ready for Tier 2	AI inventory is complete and current. Acceptable use policy is written, distributed, and acknowledged by staff. At least one accountable owner per tool. Client has adopted at least one new AI tool and used the approval process to do it.

TIER 2: OPERATIONAL GOVERNANCE — "Systematically Managed"	
Target Organization	50-250 employees. AI is embedded in multiple business functions. Some regulatory exposure or client due diligence requirements. Needs governance that works across teams and departments.
Key Deliverables	Full 14-section governance policy. Risk classification for all AI systems in the inventory. Human oversight protocols by risk tier. Vendor management process with standard assessment checklist. Incident response plan. Role-specific employee training. Quarterly review cadence established.
Time to Implement	60-120 days. Requires cross-functional participation (legal, operations, HR, leadership). 4-6 working sessions plus document review cycles.
Common Blockers	Legal review delays. Disagreement on what constitutes 'high-risk' in this specific organization. Resistance from department heads who feel the policy constrains their teams. Training rollout competing with other organizational priorities.
Signs Ready for Tier 3	Policy is functional, not just documented. Staff can answer 'what does our AI policy say about X' without looking it up. At least one incident has been processed through the incident response protocol. Client has successfully used governance to evaluate and reject or approve a new AI vendor.

TIER 3: MATURE GOVERNANCE — "Differentiated"

Target Organization	250-500 employees, or high-stakes regulated industries at any size. AI is a strategic function. Governance is a competitive differentiator. May serve enterprise clients who require governance evidence.
Key Deliverables	ISO 42001 alignment (not necessarily certification). AI ethics statement for external communication. Governance report for board or leadership. Bias audit process for high-risk systems. Governance-as-a-trust-signal communications strategy. Vendor contract clause library. Annual governance review as a formal event.
Time to Implement	Ongoing. Initial build 90-180 days. Governance is now a management function, not a project.
Common Blockers	No one owns the ongoing governance function. Review cadence breaks down when leadership attention is elsewhere. Governance documentation drifts out of sync with actual AI adoption. ISO alignment requires organizational change beyond documentation.
Signs Tier 3 is Working	Governance is referenced in sales materials and client conversations. New AI tool adoption is self-governed by staff using the established process. Leadership can answer 'what is our AI governance maturity?' with a specific, evidence-backed answer.

3.2 Designing Governance That Stays Relevant

The failure mode is a policy written in 2026 that is still in version 1.0 in 2028 while the organization has adopted twelve new AI tools. These mechanisms prevent that.

- Amendment triggers baked into the policy text (not a separate process): specific events that automatically trigger a policy review — new regulation, new AI vendor category, AI incident, organizational restructure.
- AI inventory review as a quarterly operations item: tie it to an existing meeting (quarterly business review, operations review) so it does not depend on someone remembering to do it.
- 'Tool adoption as the review trigger': every time the organization adopts a new AI tool, the inventory and risk classification process is the gate. No inventory update, no tool approval.
- Sunset clauses on vendor assessments: vendor assessments expire after 12 months and must be renewed. This forces regular contact with vendor data practices even if nothing dramatic has changed.
- Living document format: policies stored in a version-controlled document (Notion, Google Docs with version history) rather than a PDF. PDFs are archives. Living documents are systems.
- Regulatory monitoring subscription: build in a named person responsible for monitoring AI regulatory developments in the organization's jurisdictions. This can be a simple Google Alert or a paid monitoring service. Either way it must be someone's job.

7-DAY ACTION	**Draft the three-tier roadmap as a one-page visual. It will be the last slide of every discovery session — a 'here is where you are and where this goes' map that frames the follow-on engagement without selling it.**

PART 4: CONTENT STRATEGY AND EDUCATIONAL ANGLES

4.1 The Most Misunderstood Concepts in AI Governance

These are the places where confusion is widespread and your clarity creates immediate credibility. Each one is a content piece waiting to exist.

'AI governance' and 'AI ethics' are not the same thing

Ethics is the set of values that should guide AI development and use. Governance is the system that operationalizes those values inside an organization. Ethics without governance is aspiration. Governance without ethical grounding is compliance theater. Most SMB owners do not know the difference and conflate them constantly.

Having a privacy policy does not mean you have AI governance

This is the most common false belief in the SMB market. A privacy policy governs how you handle data you collect from users. It does not govern how your employees use AI tools, what data they input into those tools, or how your vendors use that data. These are entirely separate governance problems.

'Low risk' AI is not 'no risk' AI

Organizations classify their AI tools as low risk and stop there. Low risk means lower oversight requirements, not zero risk. A low-risk productivity tool that is used by every employee to handle client communications is low risk per se but high aggregate exposure. Risk classification must account for scale and breadth of use, not just individual system risk level.

NIST AI RMF is voluntary, not optional

Voluntary means there is no penalty for not adopting it. It does not mean it has no consequences. Organizations that face litigation, regulatory scrutiny, or client due diligence and cannot point to a recognized framework are at a disadvantage. 'Voluntary' is a legal status, not a recommendation to skip it.

'The vendor handles it' is not a governance answer

Vendors handle their own data practices under their terms of service. What the vendor does not govern is how your employees use the tool, what data they input, whether that use is consistent with your client contracts, or who is accountable inside your organization for the AI system's outputs. Vendor responsibility and organizational governance are different things.

Governance is a one-time project

This is the assumption that produces shelf documents. AI capabilities change quarterly. Regulations are evolving monthly. A governance document written once and never reviewed is

outdated by the time the ink dries. Governance is an ongoing management function, not a deliverable you check off.

4.2 What SMBs Are Actually Searching For Right Now

These are the real questions. Each one is a content entry point where you can provide genuine value and create awareness.

- 'Does [state] AI law apply to small businesses?' — Colorado, Texas, California variants all active
- 'Do I need an AI policy for my company?' — high-volume, low-competition keyword space
- 'Can my vendor use my data to train their AI?' — the single most urgent vendor question in 2025-2026
- 'What is an AI acceptable use policy?' — foundational question with almost no quality SMB-targeted answers
- 'ChatGPT data privacy business' — the question employees are asking when they are worried about what their employer is exposing
- 'AI bias employment law' — driven by Illinois, Colorado, and Texas regulations
- 'What to put in an AI policy' — document-building question, very high intent
- 'Is using AI with client data legal?' — urgency-driven, often post-incident
- 'AI vendor risk management' — procurement and operations audience, very underserved
- 'How to govern AI in a small company' — the exact problem you solve, almost no direct competition

4.3 Five Underserved Content Angles

1. The AI Tool Audit Walkthrough

FORMAT: Short video series (5-8 min each) + companion checklist

AUDIENCE: SMB owner-operators who suspect they have shadow AI but do not know how to find it

WHY THE GAP EXISTS: Existing resources explain what shadow AI is. None walk you through how to actually audit your organization for it, tool-by-tool, department-by-department. This is the 'how do I actually do this' gap.

HOOK: *Title: 'Find Every AI Tool Your Team Is Using Right Now (Even The Ones You Don't Know About)'*

2. Vendor Contract AI Clause Decoder

FORMAT: Template + annotated example + short video

AUDIENCE: Business owners who have signed SaaS contracts and have no idea what the AI provisions say

WHY THE GAP EXISTS: Legal blogs explain that AI clauses exist. No one has produced a plain-language decoder for SMBs that shows them what to look for, what is acceptable, and what is a red flag — without requiring a law degree.

HOOK: *Title: 'What Your AI Vendor Contract Actually Says About Your Data (And What To Do About It)'*

3. The '30-Day Minimum Viable Governance' Series

FORMAT: Email sequence or YouTube series (4-6 episodes)

AUDIENCE: Small business owners who have just discovered they have no AI policy and need to fix it fast

WHY THE GAP EXISTS: Governance resources are written for organizations with a compliance team. No one has produced a structured, week-by-week sequence for a two-person operation to get to minimum viable governance in 30 days.

HOOK: *Title: 'AI Governance in 30 Days for Businesses That Don't Have a Compliance Team'*

4. State AI Law Tracker for SMBs

FORMAT: Regularly updated reference page + email alert for subscribers

AUDIENCE: SMB owners operating in multiple states who want one source of truth on what applies to them

WHY THE GAP EXISTS: Legal firms publish state AI law summaries, but they are written for enterprise legal teams. No one has produced a clean, updated, SMB-readable tracker that maps laws to business impact — not legal citations.

HOOK: *Title: 'Which State AI Laws Apply to Your Business Right Now' (Updated Monthly)*

5. The 'What Happens When AI Goes Wrong' Case Study Series

FORMAT: Written case studies (1,000-1,500 words each) + short video summaries

AUDIENCE: Business owners who are not convinced the risk is real

WHY THE GAP EXISTS: AI failure case studies exist but are written for researchers and enterprise risk managers. No one has produced practitioner-level case studies that translate high-profile AI failures into specific lessons for SMB operators: what governance failure caused it, what it cost, and what specific governance control would have prevented it.

HOOK: *Example: 'What the NYC Chatbot Disaster Teaches Every Small Business Owner About AI Governance'*

4.4 Content Arc: First 90 Days

This is sequenced by purpose. Early content builds credibility and positions the vocabulary. Mid-sequence content generates leads. Late-sequence content creates infrastructure that compounds.

Week	Content Type	Topic / Title	Why This, Now
Week 1-2	LinkedIn post	What AI governance is (and what it is not). Three distinctions that clear up 80% of the confusion.	Vocabulary-setting. You are defining the terms of the conversation before competitors do.
Week 2-3	LinkedIn post	The statistic that should concern every SMB owner: 88% use AI, 29% have a governance plan.	Social proof and urgency. Uses the data from your research to make the case without selling.
Week 3-4	Short video or written case study	'What the NYC chatbot disaster teaches every small business owner.' 600 words or 5-minute video.	Concrete risk. The case study does what abstract risk

			explanation cannot: it makes the downside feel real.
Week 4-5	Free checklist	'The 10 AI Governance Questions Every SMB Owner Should Be Able to Answer.' Gated by email sign-up.	Lead capture. The checklist is the diagnostic in disguise. Every gap it surfaces is a reason to book a session.
Week 5-6	LinkedIn post	'Can your vendor use your data to train their AI? Here's what to look for in your contract.' With three specific clause types to find.	High urgency, high shareability. This one gets forwarded.
Week 6-7	LinkedIn post	The four maturity levels of AI governance. Where does your organization sit?	Positioning. Introduces the maturity model. Every reader who reads it thinks about their own score.
Week 7-8	Long-form article or LinkedIn newsletter	Colorado's AI Act takes effect June 30, 2026. Here's what it means for small businesses in plain language.	Regulatory hook. Combines timely news with practical guidance. This is the kind of content that gets shared by people who are worried.
Week 8-9	Free template / tool	AI Acceptable Use Policy Template for Small Businesses. Available for free with email sign-up.	Lead infrastructure. A template is a foot-in-door product. Every person who downloads it has the problem you solve.
Week 9-10	LinkedIn post or short video	'Five AI tools your employees are probably using right now without any governance coverage.' Named specifically.	Specificity converts. A list of real tools (Copilot, ChatGPT, Grammarly, Notion AI, CRM AI features) makes the abstract concrete.
Week 10-11	Case study or interview	Anonymous case study: 'How we built minimum viable AI governance for a 15-person professional services firm in 30 days.'	Social proof from work you have actually done. This is why running real sessions early matters.
Week 11-12	Email sequence launch	Launch the '30-Day Minimum Viable Governance' email series for the subscriber list you have been building.	Compounding asset. An email series nurtures the list you have built and converts subscribers who are not yet ready to book a session.

SEQUENCING LOGIC

The arc runs: vocabulary -> urgency -> risk made real -> lead capture -> expertise signals -> free tools -> social proof -> nurture infrastructure. Each phase builds on the last. Do not skip to the free tools without the vocabulary and urgency posts first. Context determines whether a free tool feels valuable or generic.

7-DAY ACTION

Write and publish the first LinkedIn post this week. The topic: 'What AI governance is, and what it is not — three distinctions that clear up 80% of the confusion.' Target 400-600 words. Publish it. The rest of the arc starts from having done step one.

PART 5: THE AI GOVERNANCE AGENT — REQUIREMENTS AND DESIGN

5.1 What The Agent Must Know and Do

This is the reality check section. A governance agent is genuinely useful if scoped correctly and genuinely dangerous if scoped incorrectly. Build from capability truth, not aspiration.

Organizational Context Intake

The agent must collect and retain organizational context before generating anything: industry, employee count, operating jurisdictions (states and countries), types of AI tools in use, existing governance documentation (if any), and specific triggering question (building from scratch? updating? responding to a specific regulation?). Without this, any output is a generic template, not governance.

Regulatory Mapping

Given the organization's jurisdiction profile, the agent must identify which regulations apply: EU AI Act (for EU operations or EU customers), applicable US state laws (Colorado, Texas, Illinois, California, Utah, etc.), sector-specific obligations (financial services, healthcare, employment). This mapping must be updatable as regulations change.

Risk Classification Guidance

The agent must be able to walk an organization through classifying their AI systems by risk tier, using the criteria defined in their applicable frameworks. It must distinguish between the EU AI Act's Annex III categories, NIST RMF risk characterization, and state law definitions of 'high-risk AI'.

Document Generation with Customization

The agent must generate governance policy sections that reflect the organization's specific context — not fill-in-the-blank templates. 'Your organization operates in Colorado and uses AI for employment screening' produces different policy language than 'your organization is a sole proprietor using AI for content creation.'

Gap Analysis Against Known Frameworks

Given an existing policy document, the agent must identify what is missing relative to a chosen framework (NIST RMF, ISO 42001, EU AI Act requirements). Output: specific gaps with severity rating and remediation guidance.

Explainer Mode

The agent must be able to explain any governance concept in plain language appropriate to a non-technical SMB owner. 'What does human-in-the-loop mean in practice for a company my size?' must produce a concrete, operational answer, not a textbook definition.

5.2 Core User Journeys

Journey 1: First-Time Governance Builder

- Collect org context: size, industry, jurisdictions, AI tool inventory
- Run regulatory mapping: which laws apply, at what threshold
- Run risk classification: tier each AI tool
- Generate: AI inventory template (pre-populated with their tools)
- Generate: Acceptable use policy (customized to their context)
- Generate: Vendor assessment checklist (for their tool types)
- Output: Governance starter package with next-step guidance
- Escalation: Flag any high-stakes areas requiring legal review

Journey 2: Updating an Existing Policy

- Ingest existing policy document
- Run gap analysis against chosen framework (NIST, ISO 42001, EU AI Act)
- Identify sections that are outdated, missing, or inconsistent
- Flag regulatory changes since the policy was written
- Generate: Updated or new sections for review
- Output: Tracked-changes version of the policy with commentary on each change

Journey 3: Responding to a Specific Regulation

- Identify the specific regulation (e.g., Colorado AI Act effective June 2026)
- Map the organization's AI systems against the regulation's high-risk definitions
- Identify compliance obligations by system and role (deployer vs. provider)
- Generate: Compliance checklist specific to the regulation
- Generate: Policy language addressing the regulation's specific requirements
- Output: Compliance gap summary with implementation timeline

5.3 Failure Mode Analysis and Design Safeguards

This is the most important section for building an agent that does not cause harm. Each failure mode has a specific safeguard.

Failure Mode	How It Happens	Safeguard

Jurisdiction hallucination	Agent cites a law or regulation that does not apply to this organization's jurisdiction, or cites a law incorrectly.	Require jurisdiction confirmation before any regulatory output. Cite sources for every regulatory claim. Never assert legal requirements without a verifiable citation. Flag all regulatory output as requiring legal verification.
Completeness false confidence	Agent generates a partial policy document and the user treats it as complete, unaware of what is missing.	Every generated document must include an explicit completeness statement: 'This document covers sections X, Y, Z. Sections A, B, C were not generated. A complete governance policy requires all 14 sections (list them).'
One-size-fits-all policy language	Agent generates generic policy language not tailored to the organization, creating a document that sounds like governance but does not reflect actual operations.	Require minimum context before generating any section. If context is insufficient, ask for it. Never generate a section from org context that is 'company in a regulated industry' — that is not enough to produce relevant policy.
Outdated regulatory content	Agent provides compliance guidance based on regulatory content that has changed since training data was last updated.	Implement a knowledge freshness flag on all regulatory content. Agent should state the effective date of the regulation as understood. User must verify against current source. Provide direct links to official regulatory sources.
Substituting for legal advice	User treats agent output as a legal opinion or uses it as a substitute for legal review in a regulated context.	Every output must include a clear, non-buried disclaimer: 'This output is a starting point for governance documentation, not legal advice. Any policy affecting employee rights, client data, or regulatory compliance should be reviewed by qualified legal counsel before implementation.'
Scope creep into technical AI design	Agent provides guidance on AI system architecture, model selection, or technical AI risk mitigation — areas outside its governance competency.	Scope the agent explicitly to governance documentation and advisory only. When a question falls outside scope (e.g., 'how do I make my model less biased?'), redirect to appropriate technical resources rather than attempting an answer.

5.4 Minimum Viable Version (V1)

V1 PHILOSOPHY	*The v1 agent does fewer things better, not more things adequately. Scope it to the highest-value, lowest-risk capabilities. The fastest way to break trust in an AI governance agent is to have it produce governance documentation that turns out to be wrong.*

V1 Does This

- Collects organizational context through a structured intake conversation
- Maps the organization's jurisdiction to applicable regulations (flags, does not interpret)
- Generates an AI inventory template customized to the organization's tool profile
- Generates an acceptable use policy (the single highest-value first document)
- Explains any governance concept in plain language on request
- Provides a gap analysis against a simplified maturity checklist

V1 Explicitly Does Not Do This

- Does not generate full compliance opinions for specific regulations
- Does not provide legal advice or claim to substitute for legal review
- Does not generate incident response plans (too context-specific for v1)
- Does not perform bias audits or technical AI assessments
- Does not advise on AI system design, model selection, or technical architecture

V2 Expansion Criteria

- V2 unlocks after: at least 50 organizations have completed the v1 intake flow, output quality has been validated against real client situations, legal review has confirmed the scope and disclaimer language is adequate, and a regulatory update mechanism is in place.
- V2 candidates: full 14-section policy generation, regulation-specific compliance checklists, vendor assessment workflow, incident response template generation.

5.5 Training Data, Knowledge Sources, and Update Mechanisms

- Primary regulatory sources: EU AI Act official text (artificial-intelligence-act.eu), NIST AI RMF (nist.gov), ISO 42001 (iso.org — standard text), state law texts from official state legislative websites
- Secondary sources: IAPP AI Governance in Practice report (updated annually), Deloitte/PwC AI governance reports, ISACA AI governance guidance
- Update trigger mechanism: monthly review of regulatory changes in tracked jurisdictions. When a material change occurs (new law effective, enforcement action that clarifies interpretation, published guidance from a regulatory body), the relevant knowledge module is flagged for review and update.
- Version control on knowledge: every knowledge module in the agent should carry a 'last verified' date and a 'next review' date. Users should be able to see when the regulatory information was last verified.
- Human review gate: all regulatory content updates must pass through a human review before going live in the agent. AI governance is not the domain where you want the agent updating its own regulatory content autonomously.

7-DAY ACTION	**Write a one-page scope document for the v1 agent: what it does, what it does not do, and the three failure modes you are designing against. This is not a technical**

spec — it is a clarity document that will prevent scope creep and keep the build grounded.

PART 6: MASTERY TIERING ACROSS THE PRACTICE

6.1 Tier 1: Must Master Before First Paid Engagement

If you cannot speak fluently to all of this without notes, you are not ready for a paid engagement. This is the minimum viable competency bar.

Domain	What Mastery Looks Like + Best Resources
AI Governance fundamentals	Can define AI governance precisely and distinguish it from data, IT, and corporate governance. Can explain all six core principles operationally. RESOURCE: Read the NIST AI RMF in full (nist.gov) — it is 40 pages and free. Read the EU AI Act executive summary. Read the full Prompt A research report.
Regulatory landscape	Can name the EU AI Act, NIST RMF, ISO 42001, and the four active state laws (CO, TX, IL, CA) and explain who each applies to and what it requires at a high level. RESOURCE: Kennedy's Law EU AI Act timeline guide. Swept AI state law tracker. Verify all regulatory details before client conversations.
Discovery session	Can run the full 60-minute diagnostic session, score the maturity model live, and produce the output template within 48 hours. RESOURCE: This toolkit. Practice with two non-paying 'beta' sessions before the first paid engagement.
Objection handling	Can respond to all seven common objections without hesitation or script. Responses are natural, not memorized. RESOURCE: The objection responses in Section 2.1. Say each one out loud five times.
Document anatomy	Can explain what every section of a complete governance policy covers and why it matters. Can distinguish between a framework, policy, playbook, and audit. RESOURCE: Section 4.2 of Prompt A research report.
SMB positioning	Can articulate in 90 seconds what a diagnostic-led solo operator offers that larger firms cannot, using specific evidence rather than generic claims. RESOURCE: Part 5 of Prompt A research report.

6.2 Tier 2: Develop Through First 3-6 Months of Client Work

These capabilities develop through real client exposure. Do not wait to accumulate all of this before starting — you will not get it from studying.

Domain	What To Develop + How
Industry-specific risk patterns	Healthcare AI creates different governance needs than professional services. Retail AI is different from financial services. After 5-10 clients, you will see the patterns. Before that, research the specific industry before each engagement. RESOURCE: IAPP's sector-specific AI governance reports. CISA sector guidelines for critical infrastructure clients.
Vendor assessment depth	The ability to read an AI vendor's terms of service and data processing agreement and identify specific governance risks. This requires practice on real contracts. RESOURCE: Read three AI vendor contracts (OpenAI,

	Microsoft Copilot, Salesforce Einstein) in full. Mark every clause related to data retention, model training, and incident notification.
Incident response design	Building an incident response plan that actually works in a specific organizational context. Every org's escalation structure and communication channels are different. RESOURCE: NIST Computer Security Incident Handling Guide (SP 800-61) for the structural model. Adapt to AI context. Review documented AI incident case studies.
Policy language craft	The skill of writing governance policy language that is specific, enforceable, and readable by a non-lawyer. Generic language is easy. Specific language that reflects actual organizational behavior requires practice. RESOURCE: Read three published AI governance policies from tech companies (Google, Microsoft, IBM). Note what makes language specific vs. generic.
Risk classification nuance	Understanding how to classify edge cases: AI tools that straddle tiers, tools that are low risk individually but high risk in aggregate, tools where the risk tier depends on how they are used rather than what they are. RESOURCE: EU AI Act Annex III (the high-risk system list). NIST AI RMF MAP function guidance.
Content flywheel management	Producing consistent educational content while running client engagements. The bottleneck is not ideas — it is execution. RESOURCE: Build a content capture system (Notion or similar) that logs insights from every client session for future content. Every client conversation produces at least one content idea.

6.3 Tier 3: Long-Term Depth That Differentiates at Scale

These take 12-24 months to build and become the moat. None of them can be acquired from a report.

Domain	What This Depth Looks Like + Path to Get There
ISO 42001 practitioner depth	The ability to guide a client through full ISO 42001 alignment, including the management system requirements, audit preparation, and certification readiness. RESOURCE: Purchase the ISO 42001 standard (iso.org, approximately $200). Complete ISACA's ISO 42001 implementation course. Pursue Lead Implementer certification if client demand warrants it.
EU AI Act compliance advisory	The ability to advise EU-adjacent clients on specific compliance obligations, risk tier classification, and documentation requirements under the Act. RESOURCE: Study the EU AI Act Article by Article (the official text is accessible at artificial-intelligence-act.eu). Follow the European AI Office's official guidance publications. Track the Codes of Practice development.
Sector-specific governance expertise	Developing deep competence in one or two specific sectors (financial services, healthcare, professional services) where AI governance has unique regulatory and operational dimensions. RESOURCE: Financial services: Federal Reserve SR 11-7 on model risk management. Healthcare: HHS AI guidelines. Professional services: American Bar Association AI ethics opinions, AICPA AI guidance.
Algorithmic bias and fairness literacy	Understanding how bias enters AI systems, how bias audits work, and how to evaluate and communicate bias risk in plain language. This is the technical depth that enables you to have credible conversations about

	fairness governance. RESOURCE: Barocas, Hardt, Narayanan 'Fairness and Machine Learning' (fairmlbook.org, free). IBM AI Fairness 360 documentation. Algorithmic Justice League resources.
Practitioner community standing	Being known in the communities where AI governance practitioners gather. This creates referral flow, peer learning, and early access to emerging regulatory developments. RESOURCE: IAPP (International Association of Privacy Professionals) AI governance community. ISACA AI Governance working group. AI Now Institute publications. Follow: Merve Hickok (AI governance practitioner), Beena Ammanath (Trustworthy AI author), Responsible AI Institute.

LEARNING PRINCIPLE

The fastest learning in this field comes from client work, not from studying. Every client engagement teaches you something about how governance works (or fails) in practice that no framework document can teach you. Start running sessions before you feel ready. You will feel ready faster.

7-DAY ACTION

Identify two people in your network for beta diagnostic sessions this week. Frame it as: 'I am doing research on how organizations are managing AI right now. I would like to run a 45-minute diagnostic session with you and give you a written summary of what I find. No charge, no pitch.' Run both sessions. The mastery compounds from there.